

UD4: Identificación y Bastionado de Sistemas

Bloques 7 · 8 | 20 horas

Marco normativo: RD 311/2022 ENS · CCN-STIC · CIS Benchmarks · NIST SP 800-123

Herramientas lab: Nmap · Nessus Essentials · OpenVAS · Sysmon · Atomic Red Team

NMAP

Descubrimiento

NESSUS

Vulnerab.

HARDENING

Bastionado

PARCHES

Actualizac.

Contenidos de la Unidad

01

Identificación de servicios y puertos

Protocolos, escaneo con Nmap, análisis de tráfico con Wireshark/tcpdump

02

Robustecimiento de sistemas (Hardening)

Credenciales, directivas, cierre de servicios, protocolos seguros

03

Gestión de parches y actualizaciones

CVE, CVSS, ciclo de vida de parches, herramientas de gestión

04

Protección frente a código malicioso

Malware, EDR, Sysmon, Atomic Red Team, comunicaciones seguras

01

Identificación de Servicios y Puertos

Bloque 7 · Protocolos, Nmap, análisis de tráfico

Administración remota

22	TCP	SSH — Shell seguro. Autenticación por clave/contraseña.
23	TCP	Telnet — Texto plano. PROHIBIDO en producción.
3389	TCP	RDP — Escritorio remoto Windows. NLA obligatorio.
5985/5986	TCP	WinRM HTTP/HTTPS — PowerShell Remoting.

Web y transferencia

80	TCP	HTTP — Sin cifrar. Redirigir a HTTPS.
443	TCP	HTTPS — TLS 1.2/1.3. Estándar seguro.
21	TCP	FTP — Sin cifrar. Usar SFTP (22) o FTPS (990).
25/587/465	TCP	SMTP/SUBMISSION/SMTPS — Correo. STARTTLS/TLS.

Servicios de red

53	UDP/TCP	DNS — Resolución de nombres. DNS over TLS/HTTPS.
67/68	UDP	DHCP — Asignación dinámica de IP.
123	UDP	NTP — Sincronización de tiempo. Crítico para logs/Kerberos.
161/162	UDP	SNMP — Gestión de red. v3 con autenticación y cifrado.

Directorio y autenticación

389	TCP/UDP	LDAP — Directorio. Usar LDAPS (636) con TLS.
636	TCP	LDAPS — LDAP sobre TLS.
88	TCP/UDP	Kerberos — Autenticación AD. Tickets cifrados.
445	TCP	SMB — Recursos compartidos. Deshabilitar SMBv1.

Nmap (Network Mapper) es la herramienta estándar de facto para el descubrimiento de hosts, escaneo de puertos, detección de versiones y OS fingerprinting. Licencia GPLv2.

Técnicas de escaneo principales

-sS	SYN Scan (Stealth)	Half-open. No completa el handshake TCP. Rápido y difícil de detectar en logs de aplicación.
-sT	Connect Scan	Full TCP handshake. Sin privilegios root. Más detectable.
-sU	UDP Scan	Escaneo de puertos UDP. Lento. Importante para DNS, SNMP, NTP.
-sV	Version Detection	Detecta versión del servicio en el puerto. Banner grabbing.
-O	OS Detection	Fingerprinting del SO basado en comportamiento de la pila TCP/IP.
-sC	Script Scan	Ejecuta scripts NSE por defecto. Equivale a --script=default.
-A	Aggressive	Combina -sV -O -sC y traceroute. Muy detectable — solo en auditorías.

Comandos de referencia — Lab SOC

```
# Descubrimiento de hosts activos en red de lab
nmap -sn 192.168.99.0/24

# Escaneo completo con detección de versión
nmap -sS -sV -O -p- 192.168.99.40

# Escaneo con scripts NSE de vulnerabilidades
nmap --script vuln 10.1.99.60

# Exportar resultados para análisis
nmap -sS -sV -oA scan_$(date +%F) 192.168.99.0/24
```

Wireshark [GUI]

Analizador de protocolos gráfico. Captura en tiempo real o analiza ficheros PCAP.

- ▶ Inspección visual de paquetes y flujos
- ▶ Reconstrucción de sesiones TCP/HTTP
- ▶ Seguimiento de flujos (Follow Stream)
- ▶ Filtros de visualización en tiempo real
- ▶ Exportación de objetos HTTP/SMB/FTP

Filtros de captura (BPF):

```
tcp port 80 and host 192.168.99.40
```

Filtros de visualización:

```
http.request.method == 'POST'
```

```
tcp.flags.syn == 1 and tcp.flags.ack == 0
```

tcpdump [CLI]

Herramienta de línea de comandos para captura y análisis de tráfico. Esencial en servidores sin entorno gráfico.

- ▶ Captura remota vía SSH
- ▶ Generación de ficheros PCAP para análisis posterior
- ▶ Filtrado por protocolo, host, puerto o red
- ▶ Integración con scripts de automatización
- ▶ Monitorización en tiempo real de tráfico

```
# Capturar tráfico SSH en vmbr1:
```

```
tcpdump -i eth1 -w lab_$(date+%F).pcap
```

```
# Filtrar por host y puerto:
```

```
tcpdump host 192.168.99.40 and port 443
```

```
# Captura en modo verbose:
```

```
tcpdump -nni vmbr1 -vv tcp
```

02

Bastionado de Sistemas

Bloque 8 · Credenciales, servicios, protocolos seguros

El bastionado (hardening) reduce la superficie de ataque eliminando configuraciones por defecto, servicios innecesarios y privilegios excesivos. Referencia: CIS Benchmarks, CCN-STIC, NIST SP 800-123.

Credenciales por defecto

- ▶ Cambiar TODAS las credenciales por defecto antes de poner en producción.
- ▶ Inventariar cuentas de admin locales en todos los sistemas.
- ▶ Deshabilitar cuentas de invitado y cuentas de demo.
- ▶ Renombrar cuenta 'Administrator' / 'root' (oscuridad como capa adicional).
- ▶ Usar gestores de contraseñas corporativos (Bitwarden, CyberArk Vault).

Separación de funciones (SoD)

- ▶ Separar roles de administrador de sistema / BBDD / red / seguridad.
- ▶ Ningún individuo controla un proceso crítico de extremo a extremo.
- ▶ Just-in-Time: acceso privilegiado temporal con aprobación de flujo.
- ▶ 4-eyes principle para operaciones de alto impacto (borrado masivo, DR).
- ▶ Registro y grabación de todas las sesiones privilegiadas (PAM).

Directivas de contraseñas y privilegios

- ▶ Longitud mínima 12 car. (NIST SP 800-63B), preferir passphrase.
- ▶ Sin expiración periódica salvo compromiso. MFA obligatorio.
- ▶ Principio de mínimo privilegio: cuenta estándar para uso diario.
- ▶ Cuentas de administrador separadas, solo para tareas administrativas.
- ▶ Revisión trimestral de privilegios elevados (PAM/AD).

Hardening de cuentas de servicio

- ▶ Usar GMSA (Group Managed Service Account) en entornos Windows.
- ▶ Contraseña de 120 car. rotada automáticamente por el DC.
- ▶ Sin login interactivo, sin derechos de admin local.
- ▶ En Linux: usuario de servicio sin shell (nologin), sin sudo.
- ▶ Secretos en vault (HashiCorp Vault, Azure Key Vault).

Servicios y puertos a deshabilitar

✗ Telnet (23)	Texto plano. Reemplazar por SSH.
✗ FTP (21)	Sin cifrado. Usar SFTP (22) o FTPS.
✗ SMBv1 (445)	Vulnerable a EternalBlue/WannaCry. Deshabilitar.
✗ SNMP v1/v2c	Sin autenticación real. Migrar a SNMPv3.
✗ rsh / rlogin / rexec	Protocolos legacy sin cifrado. Eliminar.
✗ Servicios de impresión (Windows Print Spooler)	PrintNightmare. Deshabilitar si no se usa.
✗ Acceso anónimo FTP/LDAP/SMB	Siempre requerir autenticación.

Migración a protocolos seguros

✓ HTTP → HTTPS	TLS 1.3. HSTS. Certificado válido (Let's Encrypt / CA interna).
✓ Telnet → SSH	OpenSSH. Autenticación por clave. Deshabilitar auth. por password.
✓ FTP → SFTP/FTPS	SFTP sobre SSH (puerto 22). FTPS con certificado.
✓ LDAP → LDAPS	Certificado en DC. Forzar LDAP Signing + Channel Binding.
✓ SNMPv1/v2 → SNMPv3	AuthPriv: autenticación SHA-256 + cifrado AES-128.
✓ Kerberos RC4 → AES	Deshabilitar RC4-HMAC en AD. Usar AES256-CTS-HMAC-SHA1.
✓ WEP/WPA → WPA3	Redes WiFi: WPA3-Enterprise con 802.1X y RADIUS.

03

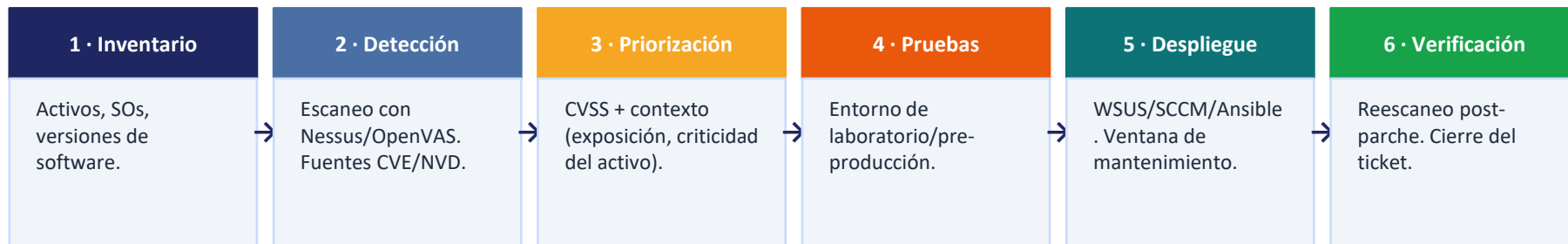
Gestión de Parches y Vulnerabilidades

Bloque 8 · CVE, CVSS, ciclo de parcheo

CVE: identificador único de vulnerabilidad (CVE-YYYY-NNNNN). **CVSS v3.1:** puntuación 0-10 de criticidad (Ninguno/Bajo/Medio/Alto/Crítico).

Ninguno	Bajo	Medio	Alto	Crítico
0.0	0.1–3.9	4.0–6.9	7.0–8.9	9.0–10.0

Ciclo de vida de la gestión de parches



SLAs de parcheo recomendados (CCN-STIC / ENS)

Crítico (9.0-10.0)	≤ 24-48 horas	Emergencia: parche o mitigación inmediata (WAF, regla IDS, segmentación).
Alto (7.0-8.9)	≤ 7 días	Ciclo de parcheo urgente. Aprobación fast-track.
Medio (4.0-6.9)	≤ 30 días	Siguiente ciclo de parcheo mensual.
Bajo (0.1-3.9)	≤ 90 días	Incluir en ciclo de parcheo trimestral.

04

Protección frente a Código Malicioso

Bloque 8 · EDR, Sysmon, Atomic Red Team, comunicaciones

Protección frente a código malicioso — EDR, Sysmon y Atomic Red Team

Bloque 8

Tipos de código malicioso

Virus	Se replica adjuntándose a ficheros ejecutables.
Gusano	Propagación autónoma por red (sin fichero huésped).
Troyano	Programa aparentemente legítimo con funcionalidad maliciosa.
Ransomware	Cifra datos y exige rescate. Variantes: locker, crypto, wiper.
Rootkit	Oculto su presencia modificando el SO a nivel de kernel.
Spyware / Keylogger	Captura datos del usuario (credenciales, pulsaciones).
RAT (Remote Access Trojan)	Control remoto del sistema por el atacante.

Capas de protección — defensa en profundidad

EDR	Endpoint Detection & Response: detección de comportamiento, contención, respuesta. Wazuh (open), CrowdStrike, Defender for Endpoint.
AV/AM	Antivirus + Antimalware: firmas + heurística + cloud sandbox. Windows Defender ATP.
Sysmon	System Monitor de Sysinternals (v15.20 en lab). Telemetría avanzada: procesos, red, ficheros, registro.
AppLocker/ AppCtrl	Lista blanca de aplicaciones. Bloquear ejecución de código no autorizado.
	Filtrado antispam, anti-phishing, sandboxing de adjuntos.

Atomic Red Team (Red Canary) es una biblioteca de tests unitarios mapeados a MITRE ATT&CK. Sysmon genera la telemetría necesaria para que el SIEM (Security Onion + Wazuh) detecte cada técnica.

Sysmon — Event IDs críticos (config en DC01)

1	Process Create	Proceso creado: imagen, cmd, hash, usuario, padre.
3	Network Connection	Conexión TCP/UDP saliente: IP/puerto destino.
7	Image Loaded	DLL cargada en proceso: hash, firmante.
8	CreateRemoteThread	Hilo remoto: indicador de process injection.
11	File Created	Fichero creado o sobrescrito en disco.
12/ 13	Registry Events	Creación/modificación de claves de registro.
22	DNS Query	Consulta DNS: dominio consultado y resultado.

Atomic Red Team — Ejemplos de técnicas ATT&CK

T1059.001	PowerShell Exec: Sysmon EID 1: powershell.exe con parámetros - enc/-nop/-exec bypass.
T1003.001	LSASS Dump: Sysmon EID 10: acceso a LSASS con OpenProcess.
T1055	Process Inject.: Sysmon EID 8: CreateRemoteThread desde proceso no habitual.
T1547.001	Autorun Regist.: Sysmon EID 13: escritura en HKCU\Run o HKLM\Run.
T1486	Ransom. (sim.): Sysmon EID 11: creación masiva de ficheros .encrypted.
T1021.001	RDP Lateral Mv.: EID 4624 Logon Type 10 + Sysmon EID 3 puerto 3389.
T1110.001	Brute Force: EID 4625 múltiples en < 60 s desde misma IP.

Comunicaciones seguras

- ▶ VPN: IPSec (IKEv2) o SSL/TLS (OpenVPN, WireGuard) para acceso remoto.
- ▶ Zero Trust Network Access (ZTNA): verificación continua de identidad y dispositivo.
- ▶ Segmentación de red: VLANs, microsegmentación. Nunca flat network en producción.
- ▶ IDS/IPS en borde: Suricata en OPNsense. Reglas ET Open + custom en lab.
- ▶ DNS sobre TLS (DoT) / DNS sobre HTTPS (DoH): evitar DNS hijacking y espionaje.

Recursos compartidos seguros

- ▶ SMB: deshabilitar SMBv1. Forzar firma SMB (SMB Signing). Usar SMBv3 con cifrado.
- ▶ NFS: exportaciones con restricción por IP. Kerberos para autenticación. NFSv4.
- ▶ Impresoras: deshabilitar Windows Print Spooler en servidores (PrintNightmare).
- ▶ Carpetas compartidas: ACLs estrictas, auditoría de acceso habilitada.
- ▶ OneDrive/SharePoint: DLP (Data Loss Prevention), etiquetas de sensibilidad.

Monitorización continua

- ▶ SIEM: correlación de eventos 24/7. Alertas en tiempo real (Security Onion en lab).
- ▶ NetFlow/IPFIX: análisis de flujos de red. Detección de exfiltración y C2.
- ▶ Honeypots: señuelos para detectar movimiento lateral (Canarytokens, Labrea).
- ▶ Threat Hunting: búsqueda proactiva de IoCs/IoAs con hipótesis MITRE ATT&CK.
- ▶ KPIs: MTTD (Mean Time To Detect), MTTR (Mean Time To Respond), volumen de alertas.

Resumen UD4

1 Nmap es la herramienta estándar de escaneo de puertos; los resultados alimentan el inventario de superficies de ataque

2 El bastionado parte de cambiar credenciales por defecto, aplicar mínimo privilegio y deshabilitar servicios innecesarios

3 Los protocolos inseguros (Telnet, FTP, SMBv1, SNMPv1/v2c) deben sustituirse por sus equivalentes seguros con cifrado y autenticación fuerte

4 La gestión de parches sigue el ciclo: inventario → detección CVE/CVSS → priorización → prueba → despliegue → verificación

5 Sysmon v15.20 (lab DC01) proporciona telemetría avanzada de endpoint que permite detectar técnicas MITRE ATT&CK en el SIEM

6 Atomic Red Team valida las detecciones del SOC simulando técnicas reales: T1059, T1003, T1055, T1486 y otras